Monthly Intelligence Dispatch

January 2022

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about relevant cyberthreats, threat groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking group members, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Russia's Security Service, the FSB, announced the arrest of **REvil** members, but it is too early to say that the group has been eliminated completely. Judging by the charges, the arrested individuals are neither REvil ransomware developers, nor affiliates who rented it; they participated in cashing out money.
- The US cybersecurity companies **Cluster25** and **Black Lotus Labs** reported about attacks against the Russian Ministry of Foreign Affairs by the North Korean hacker group Konni.
- German intelligence services accused APT27 of being involved in attacks against German commercial organizations.
- Group-IB discovered over 50 schemes involving fake investment projects and more than 8,000 domains associated with a fraudulent infrastructure.
- Fraudsters started distributing fake subscriptions disguised as concert ticket ads. Victims have money (between $66 and $262) withdrawn from their cards multiple times in several minutes with 10-15 second intervals until the balance is zero.
- INTERPOL has announced successful continuation of a joint operation called **Falcon**, involving INTERPOL, Group-IB, and the Nigerian police. 11 alleged members of a prolific cybercrime network known for business email compromise (BEC) were arrested.

Major events: **REvil**

REvil

Russia's Security Service, the FSB, announced the arrest of **REvil** members. The group was one of the oldest and most aggressive players in the ransomware business. Its numerous victims include **Quanta Computer,** a key Apple partner; **JBS Foods**, one of the biggest meat producers in the world (the group demanded as much as $70 million (!) for a data decryption key); the IT giant **Acer;** and the MSP **Kaseya**, which manages computer networks for thousands of small companies without their own IT departments. REvil actively used the ransomware-as-a-service (RaaS) model, in which developers sell or rent their malware to their affiliates for launching ransomware attacks. The group's activity was one of the key causes of the impressive ransomware market growth. The fall of REvil started at the height of their activity: after the attacks against Kaseya in July last year, the US Cyber Command, Secret Service, and FBI breached and took control of REvil servers and obtained a universal decryption key that allowed those infected via Kaseya to recover their files without paying a ransom. After that, REvil disappeared from the public eye for several months, but in September, when they tried to recover their infrastructure, they restarted some internal systems, which were already controlled by law enforcement. However, it is too early to say that Revil has been eliminated completely. Judging by the charges, the arrested individuals are neither REvil ransomware developers, nor affiliates who rented it; they participated in cashing out money. Those who are at large will certainly have difficulties in cashing out funds obtained illegally for some time. At the moment, former REvil affiliates may temporarily halt their activity or easily work with other affiliate programs. So, despite cybercriminal community's concerns over the situation with REvil, attacks involving other affiliate programs will continue.

Konni

The US cybersecurity companies **Cluster25** and **Black Lotus Labs** reported about attacks against the Russian Ministry of Foreign Affairs by the North Korean hacker group Konni. In December, the hackers sent out New Year-themed messages with a malicious file from a Ministry of Foreign Affairs staff member's account, which had been compromised in earlier attacks. The researchers likely obtained email samples from VirusTotal, a publicly available service that analyzes suspicious files and links and checks for malware. This is where the malicious email was uploaded on December 20, 2021, which is the day the attack started. We cannot say definitively that the attack was successful or assess its consequences, but what is certain is that it was detected on the same day. Further, after the VirusTotal upload, the attack came to light and, consequently, the indicators of compromise became available to security vendors, which helped update systems thereby protecting other organizations against this threat. The North Korean hackers have been trying to attack government organizations, including ones in Russia, as part of their cyber espionage campaigns for a long time. Konni is often linked to another state-sponsored APT, Kimsuky, which was discovered in 2013 (the group started activity in 2010), although we do not rule out its links to another North Korean group, APT37 (also known as Reaper, Scarcruft, Group123, and Ricochet Chollima).

Belarusian Railways

The Belarusian **Cyber Partisans** attacked a national railway company. As part of their campaign called **Peklo**, the hacktivists encrypted most of the servers, databases, and workstations of Belarusian Railways with the aim of slowing down and disrupting railway operations. In exchange for decryption keys, the group demanded the release of **50** political prisoners "who are most in need of medical assistance" and prevention of Russian troops' presence in Belarus. The hacktivists said that automation and security systems were not affected to avoid emergency situations.

APT27	German intelligence services accused APT27 of being involved in attacks against German commercial organizations with the attackers using the **HyperBro** remote access Trojan (RAT). HyperBro helps the threat actors maintain persistence on the victims' networks by acting as an in-memory backdoor with remote administration capabilities. The goal is cyber espionage and creating conditions for supply chain attacks. Based on investigations, the German intelligence services say that the attackers have been exploiting flaws in Zoho AdSelf Service Plus.
APT28	Researchers at Trellix described an espionage campaign aimed at high-ranking government officials overseeing national security policy and individuals in the defense industry in Asia. The hackers used an MSHTML vulnerability to spy on their targets. The attack is unique in that it involves Microsoft OneDrive as a command-and-control (C&C) server and has six stages to remain as hidden as possible, says the Trellix report. This approach allows the malware to go unnoticed in the victims' systems since it will only connect to legitimate Microsoft domains and will not show any suspicious network traffic. First signs of activity associated with the covert operation are said to have commenced on June 18, 2021; two victims were reported on September 21 and 29, and another 17 between October 6 and 8. Trellix says that APT28 better known as Fancy Bear is behind the attack.

Fake investments

Group-IB discovered over 50 schemes involving fake investment projects and more than 8,000 domains associated with a fraudulent infrastructure. Fraudsters suggest investing in cryptocurrencies or buying stocks of oil and gas companies, gold, pharmaceuticals, and other assets to people looking to get rich quick. In reality, the investment novices end up having their money or bank card details stolen. An ad campaign launched on social media in spring 2021 was particularly large-scale. Most frequently, fake posts featured Pavel Durov, creator of Telegram, while on landing pages and in ads threat actors used the styles of popular news resources such as Russia-24, Russia Today, and RBC. The danger is in that most of the analyzed cases are new hybrid schemes, which along with traditional phishing involve fake mobile applications and calls from “personal consultants”.

RaidForums

The personal data of 2.6 million Ukrainian citizens were put up for sale on RaidForums. The database contains full names, dates of birth, sex, phone numbers, taxpayer numbers, and ID and passport information. It was claimed that the personal data of Ukrainian was taken from the Diia service. An archive of slightly over 11 GB in size is available for preview.

3-D Secure	Fraudsters started distributing fake subscriptions disguised as concert ticket ads. Victims have money (between $66 and $262) withdrawn from their cards multiple times in several minutes with 10-15 second intervals until the balance is zero. No large-scale use of the scheme involving multiple withdrawals had been seen before. There are popular fraud schemes, such as Classiscam or Fake date, that often involve a method of gradually withdrawing funds from the victim's card. However, in these schemes, the number of times money is withdrawn is limited and fraudsters try to find out the balance on the card in advance to bring it to zero. We believe that after obtaining card details on a phishing site, a bot was launched, which initiated payments with a sublimit sum that did not require a 3-D Secure confirmation (payment security technology).
PayPal	A specialist at ESET, Jake Moore, described how to compromise a PayPal account by simple shoulder surfing. The security expert could view his friend's PayPal dashboard and all the cards associated with their account. In addition, Jake could have changed the email address for his friend's account. Shoulder surfing is a type of social engineering technique used to obtain information such as personal identification numbers (PINs), passwords and other confidential data by looking over the victim's shoulder.

Arrests and sentences

Falcon

Over a year ago we described a joint operation called **Falcon**, involving INTERPOL, Group-IB, and the Nigerian police. At the time, three individuals believed to be connected with the TMT group (dubbed so by Group-IB) were arrested. The threat group is thought to have compromised 500,000 email addresses of government and private companies worldwide. The investigation continued and some of the threat actors identified by Group-IB were at large at the time. INTERPOL later officially announced that the operation continued successfully. This time, it included the efforts of the Global Financial Crime Task Force, Nigerian law enforcement agencies, and a range of INTERPOL expert teams and its private partners, among which were Group-IB and Palo Alto Networks. As a result of Falcon II, a 10-day operation, 11 alleged members of a prolific cybercrime network known for business email compromise (BEC) were arrested. Many of the suspects are believed to belong to the TMT group (also known as SilverTerrier), which has been tracked since 2019.

Crypto farming

A network of illegal cryptocurrency farms was shutdown in Dagestan, Russia. As many as **4,343** units of computer equipment worth over **$6.5 million** were seized. Specialists estimate that the overall illegally consumed power amounted to about **8 megawatts** per hour.

IP-address spoofing

The Security Service of Ukraine eliminated a hacking service for IP spoofing. The service was organized by Ukrainian citizens including those wanted by foreign law enforcement agencies. The group carried out cyberattacks against foreign companies and provided IP-address spoofing services to other hackers. According to preliminary estimates, the group's total proceeds reached $1 million.

Forecasts and warnings

- Even though REvil members were arrested in Russia, they have successors, which is why it is a good idea to read this blog post by Oleg Skulkin, Head of Group-IB's Digital Forensics Lab, in which he describes in detail the tactics, techniques, and procedures (TTPs) used by affiliates of the REvil group. For security specialists to better prepare for attacks, the article maps REvil affiliates' TTPs in accordance with MITRE ATT&CK.
- To ensure that your card details are not compromised, only use trusted websites, do not visit short links like bit.ly or goo.gl, check whether a given link corresponds to the correct name of the company in question and does not have letters replaced with digits (e.g., the digit 0 instead of the letter O). To protect against major losses in case of fraudulent fund withdrawals, setting spending limits for bank cards or using different cards with low balances for online shopping is recommended.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com